EWB Courses: AI-Powered Cybersecurity

Assessment 01: Security foundations

Name: Khan Mohd Ruman Mohd Amir **Batch/Group:** Batch1

All work uses only the fictional data supplied in the assessment. No real systems were scanned and no real credentials or personal data were used.

Task A: Secure a student account

A1 and A2: Risk table

Risk	Asset	CIA impact	Control	Limitation
1. Same short password reused on email and portal	Email and learning-portal accounts	Confidentiality: one guessed or leaked password opens both accounts. Integrity: attacker can change data or reset other accounts via email.	Use a different long passphrase for each account, stored in a password manager.	The manager's master password becomes a single point of failure, so it must be strong and protected.
2. Approving unexpected sign-in prompts	MFA approval / active login session	Confidentiality and integrity: an approved prompt lets an attacker in even if MFA is enabled.	Approve only prompts she started herself; use an authenticator app with number matching; report unexpected prompts.	Still depends on user attention; a tired or rushed person can approve by mistake.
3. Postponed device updates	Laptop, operating system and files on it	All three: known flaws can allow malware that steals files (C), alters them (I) or locks the device (A).	Turn on automatic updates and restart when asked.	Does not stop unknown (zero-day) flaws, and old unsupported devices may not get patches.
4. Only one copy of the project	Project files	Availability: theft, damage or ransomware means permanent loss. Integrity: a corrupted file has no clean copy to compare with.	Keep a second copy in cloud storage with version history, plus an offline copy, and refresh regularly.	Synced copies can also be encrypted or deleted by ransomware; backups must be tested and protected.
5. A friend uses the laptop while Mira is signed in	Mira's account, sessions and private files	Confidentiality: friend can read mail and files. Integrity: actions are recorded as Mira's, so accountability is lost.	Give the friend a separate guest account, lock the screen when away and sign out of services.	Relies on habit; a weak device login still allows access to someone with physical possession.

Priorities (first three actions):

1. **Unique passphrases, starting with email.** Email is the recovery route for every other account, and a reused password is the easiest entry point, so fixing it removes the biggest and most likely risk first.
2. **Stop approving unknown prompts.** This is an active attack path, costs nothing and works immediately, and it protects the account even if the password is already known.
3. **Create a second copy of the project.** It is quick and protects availability against every other failure, including ones the other controls miss.

Updates and the shared laptop come next, because they are important but usually need more time or a change in habit.

A3: Authentication vs authorisation

Authentication proves who is signing in. When Mira logs into her learning portal with her password and then confirms an MFA step, the portal is checking that she really is Mira. **Authorisation** decides what that

verified person may do. Once logged in, Mira can open her own courses and submit her own work, but she should not be able to edit grades or see other students' submissions. Authentication comes first; authorisation applies the permissions after identity is established.

Task B: Analyse a suspicious message

B1: Warning signs

#	Phrase from the evidence	Why it needs scrutiny
1	"FINAL WARNING - scholarship expires in 20 minutes"	Artificial urgency is used to stop the reader from thinking or checking.
2	awards@campus-awards.example	The college normally uses campus.example. A similar-looking but different domain is a typical impersonation pattern.
3	Reply-To: help@personal-awards.example	Replies would go to a different domain from the sender, and one that looks personal rather than official.
4	"enter your college password and OTP"	A password and a one-time code are secrets that a genuine office should not ask for through a link. Together they allow a full login.
5	"Do not contact the college office"	It discourages the one check that would expose the message. Genuine organisations do not forbid verification.

The request to reply with "a photo of your identity card" is an additional red flag, since it asks for sensitive personal data.

B2: Safe verification

Do not click the link or reply. Instead, open the college portal by typing its known address or using a saved bookmark, and check for any scholarship notice there. Alternatively, use a phone number or email from the official website, notice board or student handbook, which I obtained myself and not from the message, and ask the college office or scholarship section directly.

HTTPS only means the connection to that site is encrypted. It does not show who owns the site, and criminals can also get HTTPS certificates. A **display name** such as "Scholarship Desk" can be typed by anyone and says nothing about the real sending domain.

B3: Response plan (password and OTP already entered)

1. **Contain:** on a trusted device, go to the official portal (not the message link) and change the password immediately. Choose a new unique one.
2. **Contain:** sign out of all other sessions and devices, and remove any MFA devices or recovery options that I do not recognise. If the same password is used elsewhere, change it there too.
3. **Report:** inform the college IT or helpdesk through the official contact, giving the time, the message and the sender address. If an ID photo was sent, tell the college office as well. If money or bank details were involved, contact the bank and report on the national cyber crime portal (cybercrime.gov.in).
4. **Follow up:** review recent sign-in history, email forwarding rules and account changes. Watch for unexpected OTPs or password-reset emails over the next weeks. Never send the password or OTP to anyone, including the person helping.

B4: What cannot be established

From the text alone I cannot establish **who really controls the sender address and website**, or whether a scholarship was actually awarded. Helpful extra evidence would be the full email headers and authentication results (SPF, DKIM, DMARC) reviewed by an authorised person, confirmation from the college's official scholarship list, and domain ownership records.

Task C: Triage a sign-in alert

C1: Timeline (observed vs interpretation)

Time (IST)	Observed (log / statement)	Interpretation
09:00-09:01	Password success and MFA approved from 192.0.2.10, the usual classroom IP.	Normal activity. This matches the student saying the last sign-in was around 09:05.
10:14-10:16	From new IP 198.51.100.23: two failed passwords, then a success.	Could be password guessing or a known password after some trials. The student says they did not sign in, so this was probably not them, but that is not proven.
10:17-10:18	MFA denied, then MFA approved. Student says they approved a prompt at about 10:18 to stop repeated requests.	Fits "MFA fatigue": repeated prompts led to an approval that was not part of a sign-in the student intended.
10:20	Session created from 198.51.100.23.	Access was granted. The account may now be compromised, and activity after 10:20 needs review.

C2: Explanations and checks

Likely explanation: someone obtained or guessed the password and triggered MFA prompts, and the student's approval at 10:18 let them in. **Alternative:** the student, or an app or device of theirs, signed in from a different network (for example mobile data, a VPN or a saved app login), and the student has forgotten or did not notice it.

Two checks that would help separate them:

- Compare device details (browser, operating system, device ID, approximate network owner) for the 10:14-10:20 session against the student's known devices, and see whether that device was ever registered before.
- Ask the student if they were on mobile data or a VPN at that time, and review what the session did after 10:20 (mailbox rules, new MFA methods, password changes, unusual downloads), and whether the same IP appears on other accounts.

The IP address identifies a network connection, not a person, so it cannot name who was responsible.

C3: Prioritised response actions (authorised IT team)

1. **Preserve evidence first:** export and securely store the authentication logs, session IDs and MFA prompt records for student07 before changes overwrite them, and record who accessed them.
2. **Protect the account:** revoke the active session and tokens, reset the password through a verified channel, and review or reset registered MFA methods.
3. **Investigate and harden:** review activity after 10:20, check whether other users saw the same IP, enable number matching and failed-attempt alerts or lockouts, and brief the student on not approving unexpected prompts.

C4: Incident summary

Logs show student07 signed in normally at 09:00 from the usual classroom IP. Between 10:14 and 10:20, a different IP, 198.51.100.23, had two failed passwords, a success, an MFA denial, then an approval and a session. The student says they did not sign in and approved a prompt around 10:18 to stop repeated requests. This suggests possible password compromise with MFA fatigue, but the IP does not identify a person and a legitimate off-network sign-in is not excluded. Priority: high. Next action: preserve logs, revoke sessions, reset the password and review account activity.

Task D: Review an AI security answer

D1: Unsafe or unsupported claims and corrections

#	Claim / action in the AI output	Correction and reason
1	"The email is safe because it uses HTTPS."	HTTPS only encrypts the connection. Phishing sites can use it. In Task B the sender domain is a lookalike, the reply address differs, and the message asks for a password and OTP, so it is suspicious (CISA phishing guidance).
2	"The sign-in logs prove that the person using 198.51.100.23 stole the password."	Logs show events and an IP address, not a person or how the password was obtained. The task notes that a different IP alone is not proof of an attacker. The wording should be "possible compromise".
3	"MFA prevents every account compromise."	MFA lowers risk but is not absolute. In Task C the account was still reached after a prompt was approved by mistake. OTPs can also be given away on a phishing page, as in Task B.
4	"Delete the suspicious logs."	Logs are evidence. Deleting them blocks investigation and shows what happened only to the attacker. They should be preserved and access-controlled.
5	"Send the student's password to support so they can test it."	Passwords and OTPs must never be shared, even with support. The student should change the password through the official portal and report the incident.

The confident tone of the output without evidence is itself a risk. NIST AI 600-1 calls this confabulation, where a model states false content with confidence, so AI answers should be checked against evidence.

D2: Better prompt

> You are helping with a training exercise. Analyse ONLY the synthetic evidence pasted below (a fictional sign-in log and message text). Do not ask for, accept or generate real passwords, OTPs, ID documents or personal data. Respond in these sections: (1) Observed facts: only what the evidence directly shows. (2) Assumptions or interpretations, clearly labelled as such. (3) Two possible explanations, and what extra evidence would separate them. (4) Safe, prioritised actions for an authorised IT team, including evidence preservation. (5) Your confidence level and what cannot be determined from this evidence. If the evidence is not enough, say so instead of guessing. [Paste synthetic evidence here]

D3: Corrected security advice

A message that asks for your password, OTP or ID photo, pushes urgency and discourages contacting the college should be treated as suspicious, even if its link uses HTTPS. Do not click it. Verify through the official portal or a contact you find yourself. Never share a password or OTP with anyone, including support. If you have already entered them, change your password from the official site, sign out other sessions, review your MFA devices and report it to the college IT team straight away. Approve a sign-in prompt only if you started it. IT teams should preserve logs, not delete them, and treat an IP address as a clue, not proof of who acted. MFA greatly lowers risk but does not stop every compromise, and AI output should always be checked against evidence.

D4: AI-use declaration and evidence notes

AI-use declaration: Google Gemini was used as a drafting aid for structure and wording of the answers. I reviewed and edited the content and checked it against the assessment evidence and the references below.

Evidence/reference notes:

1. CISA, *Secure Our World* (https://www.cisa.gov/secure-our-world): promotes strong unique passwords with a password manager, multifactor authentication, recognising and reporting phishing, and updating software. This supports the controls in Task A and the checks in Task B.
2. NIST, *Generative AI Profile*, AI 600-1 (https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf): describes confabulation, where AI produces confident but false output, and the need for verification. This supports the corrections in Task D.

References: CISA Secure Our World; NIST AI 600-1;